

Zero Trust Architecture

for Enterprise Security

Overview

For a long time, network security was built around a simple idea: once you are inside the office network, you can be trusted. That made sense when everyone worked in the same building and the internet was less dangerous. It does not make sense anymore. Employees work remotely. Data lives in the cloud. Attackers get inside networks regularly. Zero Trust throws out the old assumption and replaces it with a simpler rule: do not trust anything automatically, and verify every request every time.

The Core Idea

Zero Trust is not a single product you can buy. It is a set of principles that shape how a network is designed and how access decisions are made. The three principles that everything else builds on are:

Never trust, always verify

Every access request gets checked — it does not matter whether it comes from inside the office or from a remote laptop. Location inside the network is not treated as a reason to trust.

Give the minimum access needed

A person in the finance department gets access to finance systems. They do not get access to engineering files, HR records, or anything else they do not need. This limits how much damage can be done if their account is ever compromised.

Assume something is already wrong

The architecture is designed on the assumption that an attacker may already be inside. Instead of focusing only on keeping attackers out, the system is also built to contain them if they get in.

Authentication Models

Multi-Factor Authentication

A password on its own is not enough. People reuse passwords, write them down, and get tricked into giving them away. MFA adds a second requirement — usually a code from an app on your phone or a physical security key — so that a stolen password alone cannot get an attacker in. In a Zero Trust setup, MFA is not just used at login. It can be triggered again when someone tries to access something sensitive, even mid-session. The strongest form of MFA uses hardware keys (like a YubiKey) because they cannot be phished.

Role-Based Access Control

Rather than giving each employee their own custom set of permissions, RBAC groups employees by role and assigns permissions to the role. A customer support agent gets the customer support role.

That role gives access to the ticketing system and nothing else. When that person leaves, removing their access is as simple as removing them from the role. When someone gets promoted, you update their role. It keeps access management clean and reduces the risk of people accumulating permissions they no longer need.

How the Framework Was Designed

The framework is built around three layers that work together:

Identity verification

Before anyone accesses anything, they go through a central identity provider — a system that checks who they are, whether their device is healthy, and whether their access request makes sense given their location and behavior. If something looks off, access is denied or a second verification is requested.

Micro-segmentation

Instead of one flat network where a compromised machine can reach everything else, the network is divided into small isolated zones. The HR system is in its own zone. The finance system is in its own zone. Traffic between zones is inspected. An attacker who gets into one zone cannot simply walk into another.

Encryption everywhere

All data moving across the network is encrypted. All sensitive data stored on disk is encrypted. This means that intercepting traffic or stealing a hard drive does not hand the attacker readable data.

Simulation and Testing

A test environment was built using Docker containers to represent different network segments — an internal network, a cloud services zone, and a DMZ. Access policies were configured using an open-source IAM system. Three attack scenarios were then simulated to see how the framework held up:

Compromised internal account

An account with valid credentials attempted to access systems outside its assigned role. Micro-segmentation policies blocked the attempt. The access logs flagged the anomaly within four minutes.

Brute force login attack

Repeated failed login attempts triggered account lockout and an MFA escalation. The attack produced no successful logins.

Credential stuffing with stolen passwords

Leaked credentials from a public data breach were tested against the system. MFA and device trust requirements blocked every attempt, even though the passwords themselves were valid.

What Could Be Improved

The framework works well as a foundation, but a few additions would strengthen it further:

- Add behavior analytics (UEBA) to catch subtle anomalies that fixed rules miss — like an employee downloading far more data than usual.
- Use dedicated administrator workstations for any privileged tasks, separate from day-to-day machines.
- Replace traditional VPN with a software-defined perimeter for remote access — it is harder to attack and easier to manage.
- Connect to a managed security service for round-the-clock monitoring, especially outside business hours.
- Run a red team exercise every quarter specifically targeting identity and lateral movement — not just perimeter defenses.